

dyx-blog 测试报告

基于需求文档、源码静态分析与可执行验证形成

生成日期：2026-03-30

dyx-blog 测试报告

1. 测试概述

本次测试依据 `docs/requirements.md`、`docs/api-design.md`、`docs/project-usage.md`、`docs/database-design.md` 对 dyx-blog

项目进行了系统性测试评估。测试目标覆盖功能、性能、兼容性、安全性与用户体验五个维度。

本次测试实际采用了以下方式：

- 需求文档分析
- 前端源码静态测试
- 前端构建验证
- 服务器环境公开页面与公开 API 冒烟
- 服务器环境后台登录、鉴权、管理接口读写验证
- 服务器环境补充边界测试
- 数据库只读抽样核验
- 缺陷与风险归档

2. 测试环境与限制

2.1 环境

- 操作系统：Windows 11 Pro 10.0.26200
- 项目目录：`C:/Users/40179/Documents/AllProjecks/dyx-blog`
- 测试网站：`http://118.178.186.196/`
- API 前缀：`/api/site`、`/api/dyx-manager`、`/api/auth`
- 后台测试账号：`dyx`
- 数据库：`118.178.186.196:3306/dyx\_blog`

2.2 限制

- 当前仓库未包含 `backend/` 源码，无法进行代码级后端审查
- PDF 解析依赖缺失，本次改为读取同名 Markdown 源文档
- Python Playwright 缺失，无法执行浏览器自动化测试
- 按用户要求，不执行任何文件删除操作
- 本轮补充测试继续以非破坏性边界测试为主，避免删除或覆盖现网数据

3. 测试执行情况

3.1 已执行项目

1. 阅读需求、接口、使用、数据库、项目进度文档
2. 检查前端路由、登录态、HTTP 拦截器、页面模块、媒体处理、地图与交互逻辑
3. 执行前端构建命令，分析构建产物体积
4. 对服务器环境执行前台页面、公开接口、详情接口、资源链路、边界输入测试
5. 使用管理员账号执行后台登录、分页、筛选、配置、内容管理、用户管理、媒体管理、留言管理等接口测试
6. 补充后台与公开接口异常参数、错误方法、非法鉴权头等鲁棒性测试
7. 通过 MySQL 只读连接抽样核验数据库字符集、表结构与业务数据

3.2 前台测试结果

通过项

- 公开页面 `/`、`/about`、`/resume`、`/blog`、`/moments`、`/guestbook` 可访问，返回 200
- 公开接口 `/api/site/home`、`/profile`、`/posts`、`/moments`、`/projects`、`/works`、`/honors`、`/footprints`、`/guestbook` 均返回 200
- 博客详情接口可正常返回，且阅读量会递增
- 动态详情接口可正常返回真实存在的数据
- 留言提交成功；私有留言不会出现在公开留言列表
- 留言边界校验生效：空内容、空格、缺少 content、超长内容均返回 400
- 登录接口对缺失密码、空字符串和明显恶意样式输入均返回 400
- 页面访问统计接口 `POST /api/site/visit/home` 返回 200
- OSS 外部图片资源大多可正常访问

失败项

- 简历 PDF 资源访问失败，`resumePdfUrl` 对应 `/media/\*.pdf` 返回 500
- 返回数据存在系统性中文乱码
- 作品/项目部分外链缺少协议头，存在错误跳转风险
- 作品 `videoUrl` 字段实际指向图片资源
- 不存在的博客详情返回 `200 + data:null`，不存在的动态详情返回 `400`，错误语义不一致
- 公开文章列表对 `page=-1`、`pageSize=0`、`pageSize=1000` 等异常分页参数均返回 200，分页边界约束不足
- 留言接口在错误请求方法与错误字段类型输入下会触发 500
- HTML 页面响应头未见与 API 等同级别的完整安全头覆盖

3.3 后台测试结果

登录与鉴权

- 管理员账号 `dyx / 9527` 登录成功，角色为 `ADMIN`
- 未登录访问后台接口返回 401
- 错误密码登录返回 400
- 新建普通账号后，该账号登录返回“当前账号无后台登录权限”，说明后台登录权限控制生效
- 重复用户名创建返回 400，唯一性校验生效
- 缺失 token、伪造 Bearer token、错误 Authorization 方案访问后台接口时均返回 401

后台读取能力

以下接口读取成功：

- `/api/dyx-manager/dashboard/summary`
- `/api/dyx-manager/visit-logs`
- `/api/dyx-manager/users`
- `/api/dyx-manager/media`
- `/api/dyx-manager/posts`
- `/api/dyx-manager/moments`
- `/api/dyx-manager/honors`
- `/api/dyx-manager/works`
- `/api/dyx-manager/profile`
- `/api/dyx-manager/profile/hero`
- `/api/dyx-manager/system-config`
- `/api/dyx-manager/footprints`
- `/api/dyx-manager/guestbook`
- `/api/dyx-manager/projects`

后台写入/保存验证

通过（原数据回写或最小可回溯写操作）：

- 资料保存 `PUT /api/dyx-manager/profile`
- Hero 保存 `PUT /api/dyx-manager/profile/hero`
- 系统配置保存 `PUT /api/dyx-manager/system-config`
- 动态保存 `PUT /api/dyx-manager/moments/{id}`
- 荣誉保存 `PUT /api/dyx-manager/honors/{id}`
- 作品保存 `PUT /api/dyx-manager/works/{id}`

- 足迹保存 `PUT /api/dyx-manager/footprints/{id}`
- 项目保存 `PUT /api/dyx-manager/projects/{id}`
- 留言管理修改 `PUT /api/dyx-manager/guestbook/messages/{id}`
- 访问日志删除 `DELETE /api/dyx-manager/visit-logs/{id}`
- 新建用户 `POST /api/dyx-manager/users`
- 媒体预览 `GET /api/dyx-manager/media/content?...`

失败:

- 用户保存 `PUT /api/dyx-manager/users/{id}` 返回 500
- 文章保存 `PUT /api/dyx-manager/posts/{id}` 返回 500
- 文章更新不存在 ID 时返回 200, 错误语义异常
- 媒体预览缺失 `fileUrl` 参数时返回 500
- 媒体导入接口在当前存储模式下返回 400, 提示当前存储模式不支持导入本地 uploads 目录 (该行为符合当前配置, 不计为缺陷)

边界与鲁棒性补充验证

- 公开文章列表对 `page=-1`、`pageSize=0`、`pageSize=1000` 等异常分页参数均返回 200, 说明分页边界约束不足
- 留言提交接口对缺失 `content` 可返回 400, 但对错误请求方法与错误字段类型输入会触发 500
- 登录接口对缺失密码、空字符串和明显恶意样式输入均返回 400, 未触发异常
- 后台用户列表对 `pageSize=0/1000` 仍返回完整数据, 分页上限控制不足
- 后台访问日志对无效筛选值可安全返回空列表

3.4 数据库抽样核验结果

通过项

- MySQL 可成功连接, 库为 `dyx\_blog`, 版本 `8.4.8`
- 数据库、表、文本列字符集与排序规则均为 `utf8mb4 / utf8mb4\_0900\_ai\_ci`
- 数据库抽样与接口返回能够相互印证, 说明接口层并未单独篡改这些问题数据

发现项

- 业务表实际命名为 `dyx\_user`、`dyx\_post`、`dyx\_moment`、`dyx\_work`、`dyx\_project`、`dyx\_profile`、`dyx\_guestbook\_message` 等
- `dyx\_post`、`dyx\_moment`、`dyx\_project`、`dyx\_profile`、`dyx\_work` 抽样记录中已存在明显乱码, 说明脏数据已写入数据库
- `dyx\_work.video\_url` 抽样值对应 `.jpg` 图片, 和接口异常表现一致

- `dyx\_work.work\_link`、`dyx\_project.project\_link` 中存在 `www.baidu.com` 这类无协议链接，和接口表现一致
- `dyx\_profile.resume\_pdf\_url` 指向媒体路径，但线上访问仍返回 500，说明问题更可能在媒体映射/文件本体而非数据库字段缺失

4. 测试覆盖率评估

4.1 需求覆盖率（按需求项）

- 功能需求覆盖分析：16/16 已分析，覆盖率 100%
- 公开站点可执行验证：主要核心链路已验证，覆盖率高
- 后台管理可执行验证：主要读链路 with 大部分写链路已验证，覆盖率高
- 数据库级核验：已完成只读抽样验证，覆盖率中

4.2 维度覆盖率

- 功能测试：高
- 性能测试：中（完成构建产物分析，未做并发压测）
- 兼容性测试：中（完成路由与部分资源链路检查）
- 安全性测试：中到高（完成鉴权、权限、响应头、开放重定向风险检查）
- 用户体验测试：中（完成交互与数据质量检查）
- 数据库测试：中（完成只读结构与数据抽样，未做写入级事务验证）

4.3 覆盖结论

本次测试已覆盖公开站点核心功能、后台登录与主要管理能力、接口边界行为以及数据库只读抽样验证，已达到较高强度的系统测试水平；但由于缺少浏览器自动化和后端源码审查，仍未达到最终验收的最高置信度。

5. 缺陷统计分析

5.1 按严重级别统计

- P1: 7
- P2: 7
- P3: 2
- 风险项: 2

5.2 按类别统计

- 安全类: 1

- 功能类：5
- 性能类：1
- 用户体验/数据质量类：5
- 接口鲁棒性/一致性类：4
- 环境类：2

5.3 关键缺陷摘要

1. 后台登录成功后存在开放重定向风险
2. 简历 PDF 资源访问 500，下载/预览链路不可用
3. 后台用户保存接口 500
4. 后台文章保存接口 500
5. 后台文章更新不存在 ID 仍返回成功
6. 留言接口异常输入与媒体预览缺参可触发 500
7. 数据库内已存在系统性乱码脏数据
8. 外链与视频字段存在数据质量问题

详见：`docs/test/defect-log.md`

6. 风险评估

6.1 高风险

- 开放重定向问题若不修复，不建议上线后台登录链路
- 简历 PDF 不可访问，直接影响核心需求验收
- 用户管理与文章管理保存异常，影响后台核心运营功能
- 数据库中已存在乱码脏数据，若不清洗会持续污染前后台展示与后续运营内容

6.2 中风险

- 外链缺少协议头可能导致跳转错误
- 首页地图与复杂交互可能在低性能设备上出现体验问题
- 构建产物偏大，可能影响移动端与弱网体验
- 接口对异常分页参数和错误请求处理不稳健，可能增加误用与异常流量风险

6.3 低风险

- PDF 与自动化依赖缺失主要影响测试效率，不直接等同于线上生产缺陷

7. 质量结论

7.1 当前结论

系统已具备较完整的公开站点与后台管理能力，且绝大多数查询接口、登录鉴权、留言、访问统计、动态/荣誉/作品/项目/足迹/配置等链路可正常工作；但同时存在多个关键缺陷，尤其是后台保存链路异常、简历 PDF 故障、数据库层乱码脏数据和安全问题，这些缺陷足以影响上线质量判断。

7.2 上线建议

当前结论：**不通过**

原因：

- 存在 P1 安全问题（开放重定向）
- 存在多个 P1 功能问题（简历 PDF、用户保存、文章保存、错误语义异常）
- 存在数据库层已落库的系统性乱码问题，影响前后台核心展示与数据质量

8. 改进建议

8.1 必须优先处理

- 修复后台登录 redirect 校验问题，仅允许站内安全跳转
- 修复 `resumePdfUrl` 对应的媒体资源访问失败问题，重点排查文件名编码、静态资源映射和文件存在性
- 修复后台用户保存接口与文章保存接口 500
- 修复文章更新不存在资源仍返回成功的问题
- 修复留言接口与媒体预览接口对异常输入触发 500 的问题
- 全面排查数据录入/导入链路编码，并清洗数据库中的历史乱码脏数据

8.2 建议尽快处理

- 为作品/项目外链统一补全协议并在后台录入时校验
- 校验 `videoUrl` 字段真实资源类型，避免图片误填为视频
- 统一详情接口不存在资源时的错误语义
- 为 HTML 页面补充与 API 同等级别的安全头策略
- 对地图、图表、后台管理模块做进一步拆包与懒加载
- 优化首页滚动交互，减少强制滚轮劫持
- 为分页参数增加最小值、最大值校验

8.3 中长期建议

- 建立单元测试 + 集成测试 + E2E 测试体系
- 增加数据库级自动化校验和回归机制
- 增加性能基线、Lighthouse 与接口压测
- 增加安全测试清单，包括认证绕过、资源越权、上传安全、XSS/CSRF 验证

9. 附件清单

- 测试计划：`docs/test/test-plan.md`
- 测试用例：`docs/test/test-cases.md`
- 缺陷清单：`docs/test/defect-log.md`
- 测试报告 PDF：`docs/test/test-report.pdf`